

보안 점검표 제공과 AI 피싱 메일 분류 성능

무료 채팅 환경에서 수행한 20개 메일의 짝지은 탐색 연구

정동석

작성일 2026년 9월 16일

관심 분야 AI를 활용한 정보보안

초록

본 연구는 보안 점검표 제공이 AI의 피싱 메일 분류 정확도를 높이는지 확인하였다. 공개 자료에서 정상 메일 10건과 피싱 메일 10건을 선정하고, 기본 지시 조건 A와 다섯 항목의 점검표를 추가한 조건 B를 같은 메일에 적용하였다. 사용자는 Gemini 무료 채팅의 새 대화에서 40회 판정을 기록했으며, 모델명은 사용자 보고에 따라 Gemini 3.5 Flash-Lite로 표기하였다. 최초 저장본의 요청문 혼입 2건은 사용자가 제공한 원 답변으로 보완하고 변경 이력을 남겼다. 보완 후 두 조건 모두 20건 중 20건이 출처 라벨과 일치하였다. 정확도 차이는 0퍼센트포인트였고, 짝지은 불일치 사례는 없었다. 이 표본에서는 점검표의 추가 개선이 관찰되지 않았으나, 작은 표본과 천장효과 때문에 효과가 없다고 확정할 수는 없다.

핵심어 피싱 탐지 · 보안 점검표 · 대규모 언어 모델 · 무료 채팅 · 재현성

1 서론

피싱 분석 도구를 개발하려면 정답을 제시하는 것뿐 아니라 어떤 지시 방식이 판단을 개선하는지 검증할 필요가 있다. 본 연구는 별도 학습 없이 제공할 수 있는 보안 점검표를 주목한다. 정동석은 보안·AI에 대한 관심과 후속 개발 가능성을 기준으로 이 주제를 선택했다. 연구 결과는 메일 내용을 입력받아 의심 근거를 보여 주는 도구의 초기 설계 자료로 활용할 수 있다. 다만 이번 실험은 운영 환경의 성능 평가가 아니다.

1.1 선행 연구와 연구 범위

Macatangay(2025)는 피싱 특징과 설득 단서를 결합한 CARLS 점검표를 제안하고 평가하였다. 이는 점검표를 AI 기반 판단에 활용하는 직접적인 선행 사례다. Desolda, Greco와 Viganò(2025)는 APOLLO를 통해 GPT 기반 메일 분류와 설명을 평가했다. 두 연구의 존재와 실험 설명은 대학 저장소 및 출판사 초록에서 확인하였다. 본 연구는 CARLS를 그대로 구현하거나 APOLLO의 성능을 재현했다고 주장하지 않는다. 알려진 사실은 점검표 및 LLM 기반 피싱 탐지 연구가 있다는 것이고, 새로 확인할 사항은 본 표본과 지시문에서의 A와 B 차이다.

1.2 검토한 후보와 선택 이유

후보	선정 또는 제외 이유
긴급 표현과 피싱 오탐	단일 요인에 국한되어 개발 기능의 범위가 좁아 제외
프롬프트 인젝션 방어	공격 유형과 성공 기준 검증 부담으로 제외
코드 취약점 탐지 점검표	코드 정답 검증과 실행 환경 구축 부담으로 제외
피싱 탐지 보안 점검표	같은 메일의 조건 비교가 가능하고 분석 도구 개발과 연결되어 선정

1.3 가설

발신자·링크·요청 행동·압박 표현·맥락을 확인하는 고정된 보안 점검표를 제공하면, 동일한 AI 채팅 환경에서 정상·피싱 메일의 분류 정확도가 기본 지시만 제공할 때보다 높아진다.

독립변수는 점검표 추가 여부, 종속변수는 출처 라벨과 일치한 판정의 비율이다. B의 정확도가 A와 같거나 낮으면 예상한 개선이 관찰되지 않은 것으로 해석한다. 결과를 본 뒤 가설의 방향을 바꾸지 않았다.

2 방법

2.1 공개 자료와 표본 선정

2026년 9월 16일 Jose Nazario의 20051114.mbox와 Apache SpamAssassin의 20030228_easy_ham 및 20030228_hard_ham 원자료를 확보했다. Nazario 자료의 피싱 라벨과 SpamAssassin의 비스팸 라벨을 기준 정답으로 사용했다. 비스팸이 절대적인 안전성을 보증하지 않으며, 스팸 전체를 피싱으로 바꾸어 사용하지 않았다. 원자료 파싱 3,188건에서 길이 기준 98건, 문자 비율 기준 2건, 완전·근접 중복 301건을 제외해 2,787건이 남았다.

기존 API 계획에서는 본 표본 100건과 예비 10건을 선정했다. 그러나 API 크레딧 부족으로 성공 응답을 수집하지 못했고, 사용자의 무결제 요청에 따라 본 표본에서 정상 10건과 피싱 10건을 층화 무작위 추출했다. 정상은 easy_ham과 hard_ham에서 각각 5건이다. 추출 시드는 20260917이며 모델 결과를 보기 전에 고정했다. 원 계획, 변경 사유, 표본 식별자와 원문을 재현 패키지에 보존했다.

2.2 조건과 측정

항목	실행 내용
조건 A	피싱 정의와 JSON 출력 형식을 포함한 기본 지시
조건 B	동일 기본 지시에 발신자·링크·요청 행동·압박·맥락 점검 추가
고정한 항목	선정 메일, 기본 지시, 출력 형식, 같은 서비스와 새 대화
표본과 반복	메일 20건에 A/B 각 1회, 총 40회; 별도 채팅 예비 실험 없음
환경 기록	제미나이 / 새 대화. 모델명은 사용자 후속 보고 3.5flash-lite
측정값	정확도, 정상 오탐, 피싱 미탐, 무효 기록 수, 메일별 A/B 일치

메일의 발신자·제목·본문을 제공하고 HTML의 링크 목적지를 텍스트로 보존했다. 정답, 자료 출처, 원 파일명과 기존 필터 판정 헤더는 요청에서 제외했다. 두 조건 모두 짧은 판단 근거를 요구하고, 메일 내부 지시는 따르지 않도록 했다. 조건 B는 정보가 없다는 이유나 단일 단서만으로 피싱을 단정하지 않도록 안내했다.

2 방법 계속

2.3 실행 환경과 원자료 관리

기록 시각은 2026년 9월 16일 14시 47분 12초부터 14시 55분 09초까지이다(한국 표준시). 이는 수집 화면에 응답을 저장한 시각으로, 모델의 생성 지연시간은 아니다. 사용자가 새 대화에서 판정한 응답을 수동으로 붙여넣었다. 서버 응답 ID, 채팅 전체 내보내기, 정확한 백엔드 버전은 확보하지 않았다. 메모리·맞춤 지침·검색 설정과 temperature도 로그에서 확인할 수 없어 완전히 통제했다고 주장하지 않는다.

모델명 Gemini 3.5 Flash-Lite는 사용자가 알려준 이름이며 공식 모델 목록이나 화면 증거로 독립 검증한 식별자가 아니다. 따라서 특정 버전의 엄밀한 벤치마크보다, 사용자가 보고한 무료 Gemini 채팅 환경에 대한 탐색 관찰로 해석한다.

2.4 기록 오류와 보완

최초 JSON에는 T13(E011, B)과 T30(E050, B)에 응답 대신 요청문이 저장되어 있었다. 두 텍스트는 공백을 정규화하면 해당 요청문과 일치했다. 최초 파일과 SHA-256을 보존하고, 원래 첫 답변을 찾으려 요청했다. 사용자가 두 피싱 판정과 근거를 제공했으며 이를 별도 보완본에 반영했다. 새로 질문해 유리한 답변을 얻도록 요청하지 않았다. 다만 제공된 답변이 원 대화의 첫 답변이라는 점은 채팅 내보내기로 독립 확인하지 못했다.

2.5 분석 계획

주평가는 메일 20건의 출처 라벨 일치율과 B-A 차이다. 정상 오탐과 피싱 미탐의 분모는 각각 10건이다. 무효 응답은 정확도에서 실패로 포함하고 오탐·미탐과 분리한다. 동일 메일 쌍의 불일치 수로 양측 exact McNemar 검정을 적용하며, 불일치가 0이면 코드 규칙상 $p=1$ 을 반환한다. 클래스별로 쌍을 유지하는 부트스트랩 10,000회도 수행한다. 분석 코드는 동결된 계획과 표본의 해시를 확인한다.

기록 보완의 영향을 숨기지 않기 위해 최초 저장본, 유효한 18쌍의 사후 보조 분석, 보완 후 20쌍을 모두 보고한다. 앞서 표시한 모호한 E092와 독일어 4건은 이번 20건에 선택되지 않아 해당 제외 분석은 적용하지 않았다. 보완 후 각 조건의 Wilson 95% 구간은 추가적인 사후 설명으로 제시하며, 두 조건 차이의 구간으로 해석하지 않는다.

3 결과

분석 대상	A	B	B-A
최초 저장본 20건	20/20 (100%)	18/20 (90%)	-10%p
유효 응답이 있는 18쌍	18/18 (100%)	18/18 (100%)	0%p
원 답변 보완 후 20쌍	20/20 (100%)	20/20 (100%)	0%p

최초 저장본에서 B의 실패 2건은 피싱을 정상으로 분류한 사례가 아니라 요청문 혼입으로 판정을 읽을 수 없는 기록이다. 최초 분석의 양측 p값은 0.5였으며, 그 차이를 점검표가 모델 성능을 악화시킨 증거로 해석할 수 없다. 유효한 18쌍의 두 조건은 모두 출처 라벨과 일치했다.

보완 후 지표	A 기본 지시	B 점검표 추가
피싱 정분류 TP	10	10
정상 정분류 TN	10	10
정상 오탐 FP	0/10	0/10
피싱 미탐 FN	0/10	0/10
무효 기록	0	0
A만 정답 / B만 정답	0 / 0	짜지은 불일치 없음

보완 후 정확도 차이는 0퍼센트포인트이며 exact McNemar $p=1.0$ 이다. 이는 조건 차이를 보여 주는 불일치 사례가 없다는 뜻이다. 각 조건의 20/20에 대한 Wilson 95% 구간은 약 83.9~100%이며, 모집단 정확도가 100%라고 확정할 수 없다.

보완 후 짜지은 부트스트랩 차이 구간은 $[0, 0]$ 으로 계산된다. 모든 관측쌍의 차이가 0이므로 재표집해도 차이가 달라지지 않는 퇴화 결과다. 효과가 정확히 0임을 증명하거나 두 조건의 동등성을 입증하는 구간으로 해석하지 않는다.

가설과 부합한 부분은 점검표 조건에서도 모든 메일을 정분류했다는 사실이다. 그러나 핵심 예측인 기본 지시 대비 정확도 상승은 관찰되지 않았다. 전체 메일별 결과는 부록에 제시하며 반대 결과나 무효 기록을 삭제하지 않았다.

4 논의와 결론

4.1 개선이 관찰되지 않은 이유

첫째, 기본 지시 조건부터 100%였으므로 정확도가 더 높아질 여지가 없는 천장효과가 있었다. 둘째, 오래된 피싱의 위협 문구·외부 링크 등 비교적 뚜렷한 단서와 정상 뉴스레터·기술 토론이 구분하기 쉬웠을 수 있다. 셋째, 정상과 피싱을 서로 다른 출처에서 가져와 문체나 시대의 차이가 분류에 영향을 주었을 수 있다. 첫 번째 가능성은 관측값으로 확인되지만 나머지는 별도 난도·출처 통제 실험 없이 원인으로 확정할 수 없다.

출력 근거가 그럴듯해 보이더라도 이 실험은 설명의 사실성·사용자 이해도·실제 링크 안전성을 별도로 평가하지 않았다. 일부 응답의 검색 링크 형식도 기록에 남아 있으나, 이것만으로 검색 도구가 실제 실행됐다고 판단할 수 없다. 운영 도구를 만들 때는 입력에서 확인한 사실과 모델의 추정을 구분하여 표시해야 한다.

4.2 한계와 후속 개발

표본은 정상 10건·피싱 10건에 그치며 실제 받은편지함의 피싱 비율과 다르다. 자료가 오래되었고 공개 학습 데이터 포함 여부를 알 수 없다. 중복 제거 후에도 유사 캠페인이나 스레드의 종속성이 남을 수 있다. 모델명과 대화 조건은 사용자 기록에 의존하며, 반복 실행의 변동성·모델 변경·개인화 영향을 확인하지 못했다. 두 답변 보완의 출처도 독립 대화 로그가 없어 검증 수준이 제한된다.

향후에는 출처와 시기를 맞춘 더 큰 표본, 어려운 정상 사례, 같은 모델 버전의 반복 평가가 필요하다. 점검표 내용과 단순히 지시문이 길어진 효과를 분리하려면 길이를 맞춘 대조 조건도 추가해야 한다. 한국어·실제 업무 메일이나 자동 차단 시스템의 성능으로 일반화하지 않는다. 후속 시제품에서는 메일 입력, 위협 근거 표시, 확인 불가 항목 표시를 구현하고 추가 평가를 진행할 수 있다.

4.3 최종 결론

본 탐색 연구에서는 보안 점검표를 추가해도 기본 지시 대비 피싱 메일 분류 정확도가 높아지지 않았다. 보완된 20개 메일에서 두 조건 모두 출처 라벨과 일치했으며, 점검표의 추가 효과를 지지할 관측 차이는 없었다. 다만 작은 표본과 기본 조건의 천장효과 때문에 점검표가 불필요하다거나 어떤 환경에서도 효과가 없다고 결론 내릴 수 없다. 본 연구의 결과는 초기 분석 도구의 가능성을 제한된 표본에서 확인하고, 더 어려운 자료와 엄격한 환경 통제가 필요한 후속 검증 과제를 드러낸다는 데 의미가 있다.

참고문헌

Macatangay, X. (2025). Checklist-based phishing detection leveraging Large Language Models. 석사학위논문, University of Turku. 영구식별자 URN:NBN:fi-fe2025061166683.

Desolda, G., Greco, F., & Viganò, L. (2025). APOLLO: A GPT-based tool to detect phishing emails and generate explanations that warn users. *Proceedings of the ACM on Human-Computer Interaction*, 9(4), Article EICS003. DOI: 10.1145/3733049.

Apache SpamAssassin. (2006). Public mail corpus README. 원자료 설명서, 2006년 1월 31일 갱신 표기. 사용 파일 20030228_easy_ham.tar.bz2 및 20030228_hard_ham.tar.bz2.

Nazario, J. (연도 미상). Phishing corpus. 공개 데이터 모음. 사용 파일 20051114.mbox, 제공자 README 및 CC BY 4.0 라이선스.

출처 확인과 제외 문헌

문헌은 AI가 검색한 목록을 그대로 인용하지 않고 대학 저장소와 출판사 페이지에서 저자·제목·연도·초록을 확인했다. 전문을 모두 정독했다는 뜻은 아니다. 데이터는 원 배포처 설명 및 다운로드 파일의 해시를 보존했다. 확인일은 2026년 9월 16일이다. 문헌별 가설 연결과 원출처 주소는 재현 폴더의 REFERENCES.md 및 download_manifest.json에 있다.

Seven Phishing Email Datasets는 스팸 라벨 전체를 피싱으로 간주할 위험 때문에 해당 사용 방식을 제외했다. MeAJOR는 주소 익명화로 발신자·링크 점검 정보가 줄어 제외했다. Prompt Engineering or Fine-Tuning? A Case Study on Phishing Detection with Large Language Models는 출판사 조회 오류로 내용 확인이 불충분하여 핵심 인용에서 제외했다.

재현 방법

reproduction 폴더에서 Python 3.10 이상으로 python analyze.py free_responses.json을 실행하면 40개 저장 응답으로 결과를 다시 계산한다. 새 API 호출이나 결제는 필요 없다. free_results.json에 전체 예측·통계가 저장된다. 최초 파일과 보완 내역은 evidence 폴더에 있으며, 재수집 지침·40개 요청문·20개 원문도 함께 제공한다. 최초 판정 자체의 재실행은 무료 서비스의 모델 및 설정 변화 때문에 동일 결과를 보장하지 않는다.

AI와 연구자의 역할

정동석은 보안·AI 관심 분야와 개발 가능성이라는 기준으로 주제를 선택하고 무료 채팅에서 응답을 수집했으며, 모델명과 두 누락 답변을 제공했다. AI는 문헌 검색·자료 확보·설계·전처리·통계 계산·원고 작성을 보조했다. 이 원고의 통계 해석은 AI가 제안한 것으로, 연구자가 별도의 전문 검증이나 독립적인 최종 판단을 수행했다고 주장하지 않는다.

부록 전체 메일별 판정

메일 ID	출처 라벨	A	B	기록 상태
E001	피싱	일치	일치	원 기록
E011	피싱	일치	일치	T13 보완
E013	피싱	일치	일치	원 기록
E025	피싱	일치	일치	원 기록
E027	정상	일치	일치	원 기록
E029	피싱	일치	일치	원 기록
E033	피싱	일치	일치	원 기록
E042	정상	일치	일치	원 기록
E046	정상	일치	일치	원 기록
E050	피싱	일치	일치	T30 보완
E055	정상	일치	일치	원 기록
E069	정상	일치	일치	원 기록
E074	정상	일치	일치	원 기록
E077	피싱	일치	일치	원 기록
E079	정상	일치	일치	원 기록
E091	피싱	일치	일치	원 기록
E093	정상	일치	일치	원 기록
E094	피싱	일치	일치	원 기록
E098	정상	일치	일치	원 기록
E102	정상	일치	일치	원 기록

보완은 두 칸의 요청문 혼입을 사용자가 제공한 응답으로 복구한 것이다. 최초 저장본을 삭제하거나 가설에 맞게 정답 라벨을 변경하지 않았다. 링크는 과거 메일의 분석 자료이며 실제 접속하여 안전성을 확인한 것이 아니다.